PRAISING HARRIS

AI SECURITY / AGENT & MCP SECURITY / LLM RED TEAMING

9597691821 | praisingharris@gmail.com | github.com/Pyhroff | medium.com/@praisingharris
linkedin.com/in/praising-harris-8a3320330 | tryhackme.com/p/Pyhroff

5 merged PRs (SQLGlot, LiteLLM, SQLFluff) · PyPI 0.6.0 aisec-suite · 56.9% AgentDojo runtime guard

PROFILE

AI security undergraduate building and measuring defensive tooling for LLM agents: scanners for MCP tool poisoning, RAG and agent-memory injection (aisec-suite, 4 PyPI packages), implementations of published jailbreak attacks, and fixes contributed upstream to LiteLLM, FastMCP, the MCP Python SDK and SQLGlot. Reports false-positive rates and negative results alongside headline numbers.

EDUCATION

Indian Institute of Information Technology, Kottayam 2024 – 2028 (expected)
B.Tech Computer Science & Engineering (Cybersecurity) | CGPA 7.9

EXPERIENCE

VAPT Intern (Remote), Cyberops Jul 2026 – Oct 2026

- Completed company-assigned vulnerability assessment and penetration testing training covering Burp Suite, Nmap and the OWASP Top 10, practised on TryHackMe and HackTheBox machines.

PROJECTS

Open-Source Security Contributions: LiteLLM, FastMCP, MCP Python SDK github.com/Pyhroff
5 merged: SQLGlot #8780, LiteLLM #47091, SQLFluff #8901, #8902 · others open

- LiteLLM: found an authorization bypass where keys and teams with access-group IDs but an empty direct model list fell back to wildcard access to every model (self-assessed CVSS 7.5); opened fix PR #47105 with unit tests, and PR #47312 scoping /v1/mcp/access_groups to servers the caller can access.
- FastMCP (PR #6063): added a wall-clock timeout and an external-callback limit to the CodeMode sandbox so a runaway script cannot starve the host event loop (65/65 tests pass). MCP Python SDK (PRs #3764, #3765): OAuth error-response (RFC 6749 §5.2) and header-whitespace (RFC 9110) fixes.
- SQLGlot (merged #8780): fixed lambda transpilation mutating a shared DataType node, which silently corrupted casts in multi-argument lambdas. LiteLLM (merged #47091): Cohere stop-sequence mapping. SQLFluff (#8899–#8902): four dialect-grammar fixes.

aisec-suite 0.6.0: Unified AI-Security Scanner with SARIF Output **github.com/Pyhroff/aisec-suite**
Python · Typer · AST taint analysis · SARIF · GitHub Actions · PyPI

- Published aisec-suite, pyhroff-mcpaudit, memsentry and pyhroff-ragsentry to PyPI; one command runs all three scanners on a repo and writes SARIF for GitHub code scanning, with a baseline mode that fails CI only on new findings and a reusable GitHub Action.
- Added Python AST and JS/TS reachability analysis that marks tool-scope findings as reached, guarded or absent (zero wrong refutations on 120 labelled findings) and a structural tool-poisoning detector that decodes hidden text (invisible Unicode, bidi, base64, hex, rot13).
- Measured on third-party benchmarks: 14.0% recall on MCPTox/MCP-Poison-Bench (0 FP on 362 real tools). Built a runtime provenance guard stopping 56.9% of AgentDojo attacks (99.3% banking, 95.2% Slack) without reading prose intent.

Scanner Precision Study on Public MCP Servers github.com/Pyhroff/aisec-suite
mcpaudit v0.6 → v0.7 · memsentry v1.2 · manual triage

- Ran the scanners over about 90 public MCP-server repos and hand-checked the results: only 37.5% (95% CI 24–53%) of mcpaudit v0.6 HIGH permission_scope findings were accurate and no flagged repo had genuine tool poisoning.
- Patched the false-positive sources and shipped mcpaudit 0.7 and memsentry 1.2, and documented the method and findings in the repo.

agent-security-ci · trainsentry · loopcheck github.com/Pyhroff/agent-security-ci
Python · Typer · pytest · GitHub Actions

- trainsentry flags backdoor trigger phrases in fine-tuning datasets; loopcheck flags duplicate and thrashing tool calls in agent traces.
- Wired all five scanners into a CI gate that runs against a clean and a vulnerable toy agent and fails the build if any scanner misses its known-bad fixture; 254 tests across the five tools.

PromptStrike: LLM Red-Teaming Framework github.com/Pyhroff/promptstrike
Python · FastAPI · WebSocket · SQLite · GitHub Actions

- Implemented PAIR, TAP, Crescendo and GCG (white-box) jailbreak attacks from their papers, scored by a JailbreakBench-style 1–10 judge, with 50 behaviour goals mapped to the OWASP LLM Top 10 and a multi-model sweep across Groq, OpenAI and Ollama.
- Added a CI gate that fails a build when attack success rate exceeds a threshold, and a Defense Shield (10-rule input scanner plus output jailbreak classifier) that wraps any model adapter as a transparent proxy; 61 tests pass offline.

AdversaGen: Adaptive Attack-Payload Generator github.com/Pyhroff/adversagen
Python · SciPy · evolutionary search

- Evolved evasions (zero-width characters, homoglyphs, paraphrase, indirection) against a naive blocklist on four surfaces (prompt injection, tool poisoning, memory injection, RAG injection); 240 runs (30 seeds × 2 conditions × 4 surfaces).
- Found random mutation beat reflection-guided mutation on every surface (evasion 0.86–0.91 vs 0.63–0.72, $p < 0.0001$), traced it to lost population diversity, and reported the negative result rather than tuning it away.

agent-install-guardrail & wormsentry: Supply-Chain Pre-Install Gate github.com/Pyhroff/agent-install-guardrail
Python · MCP Server · Typer CLI · AST / Registry Inspection

- Shipped a pre-install risk gate (MCP server + enforcing CLI) for AI coding agents and wormsentry static analysis for Shai-Hulud-style self-propagating npm/pip worms (install-script hooks, credential harvesting, and token-read + publish propagation).

ModelHawk: ML Model Backdoor Scanner github.com/Pyhroff/ModelHawk
Python (stdlib only) · pytest · GitHub Actions

- Detects pickle-deserialization code execution in PyTorch model files by disassembling the opcode stream (REDUCE / __reduce__ chains) without loading the model, with a generator for harmless malicious samples; 8 tests pass. Write-up published on Medium.

Proxy: Prompt-Injection-Resistant Browser Agent (duo project) github.com/Pyhroff/proxy-hackathon
Python · FastAPI · Playwright · Docker

- Every browser action passes a policy gate and a scanner for hidden page content; sensitive fields (SSN, DOB) are entered by the user and never enter the model's context. Includes a written threat model and tests.

SOC PARALLAX: Behavioural Detection Platform github.com/Pyhroff/soc-parallax
Python · LangGraph · FastAPI · Neo4j · PostgreSQL · Ollama · Docker

- Deterministic LangGraph investigation pipeline over Windows attack telemetry with per-entity baselines, ATT&CK mapping from a versioned rulebook (not LLM output), and a grounding guard that blocks narratives citing anything absent from the evidence.

SKILLS

AI security MCP tool-poisoning, RAG and agent-memory injection detection, AST taint / reachability analysis, SARIF, PAIR/TAP/Crescendo/GCG jailbreaks

Engineering Python, JavaScript, SQL, Bash; FastAPI, LangGraph, pytest, GitHub Actions, Docker, Ollama, Groq and OpenAI APIs, Neo4j, PostgreSQL

Security tooling Burp Suite, Nmap, MITRE ATT&CK, Sigma / EVTX, TryHackMe and HackTheBox labs

CERTIFICATIONS, WRITING & HACKATHONS

TryHackMe AI Security path (Jun 2026) and Pre-Security path; top 2% globally, 177 rooms completed. Fortinet: Introduction to the Threat Landscape (NSE 1).

Medium six articles on agent and AI security, including "I Built a Malware Scanner for AI Models. Here's What I Found".

Hackathons PSBs Hackathon 2026 (PhantomGrid, behavioural-biometric authentication); USAII Global AI 2026 (Lucid, LLM extraction with a deterministic rules engine and faithfulness guard).